

# From AI-found bugs to installed protection

Eric Buess | One-page approval draft 1.3 | September 13, 2026

Thank you, Logan, for offering to take a short document to the team. I read the thread as a call for a practical lab-backed effort to make a large share of systems harder to compromise while alignment remains unresolved. A lab could put capped compute and engineering behind shared repairs and owner-authorized deployment, then verify their reach. A pilot could test that delivery mechanism; it would not establish global coverage or settle alignment.

**The lab-level proposal.** Dedicate a capped defensive-compute and engineering budget to three connected tasks: improve widely shared software and defaults; help owners safely install those changes; and verify adoption and remaining attack paths. Work through maintainers, package and platform releases, cloud providers and managed fleets. That distribution is the proposed route to broad reach. Build on existing initiatives such as Glasswing and AI-assisted browser security work.

Choose channels by reachable exposure, security importance, update authority and observed adoption. Fund the limiting stage-discovery, review, testing or rollout-rather than maximizing findings. Pair donated cycles with maintainer/operator support. Supported firmware and infrastructure configuration fit this approach; hardware redesign and unsupported devices need separate paths.

**Start with a 90-day pilot.** With a consenting maintainer and operator, select one repeatable web-service deployment class. Finalize permissions, baselines and stop conditions; assemble 20-40 replayable feasibility tasks, including failures and recovery; then run limited canaries and independent review. Expand only if results justify it.

For supported, previously reviewed upgrades and mitigations, target verified canary improvement within one hour of admission. Novel or high-consequence changes take an engineering path. Also measure submission-to-full-deployment time: an hour-long canary is an intermediate milestone, not the full owner experience you described. Retain rejected cases, delays, regressions and failures. Define disruption and follow-up criteria with the operator; successful rollback does not erase an outage.

**What would count.** Compare against the operator's normal process under declared budgets. Measure addressed exposures, adoption, time, operator effort, regressions and recovery. Report verified protection for specified attack paths over a declared period, not that every patched system is secure. Deduplicate installed populations, retain unknowns and distinguish current attacker tests from future capabilities. There is no defensible global percentage yet.

Keep patch authorship, verification and deployment authority separate. Limit credentials, stage rollouts in small cohorts, and test whether a compromised defender or control channel could spread a harmful change. Preserve an operator-controlled stop and recovery path.

**Resources.** An illustrative 90-day envelope is 8-12 full-time-equivalent staff and approximately \$0.7-\$1.6 million, including infrastructure and review. These are planning assumptions; approve a capped first phase after partner scoping. They do not price a global rollout.

I developed this proposal with Titus, the coordination workflow I am building, using research and critiques from several model families. Its review record includes limitations; whether the process improves on a strong single model remains to be tested. Open-weight participation is still to be added.

Which distribution partner and deployment class would make the most useful first test? I would welcome corrections and pointers to work we should build on.

*Full proposal and review record accompany this draft. No pilot, partnership, funding or endorsement is claimed.*